PATH TRAVERSAL

PortSwigger Web Security Academy Lab Report

Prepared by: Sofia

Focus: Web Application Security / WAPT Foundations

Platform: PortSwigger Web Security Academy

Lab: File path traversal, simple case

IqraSec Academy - WAPT Internship - Phase 1

1. Executive Summary

The product images of this shop are loaded with a filename parameter. By using ../ sequences I read the /etc/passwd file from the server.

2. Lab Information

Platform	PortSwigger Web Security Academy
Room / Lab	File path traversal, simple case
Primary Domain	Web Application Security
Purpose	Foundational WAPT practice
Completion	Completed - lab solved
Link	https://portswigger.net/web-security/file-path-traversal/lab-simple

3. Learning Objectives

- Understand path (directory) traversal.
- Find a parameter that holds a file name.
- Read a file outside the web folder.

4. Vulnerability / Concept

Path traversal lets an attacker read files outside the intended folder by using ../ in a file name parameter, because the application does not validate the path.

5. Testing Approach

I opened a product page and found the image request /image?filename=.... I captured it in Burp, sent it to Repeater and changed the value to **../../../etc/passwd**. The server answered 200 and the body showed the file content (root:x:0:0...). The lab was solved.

6. Evidence

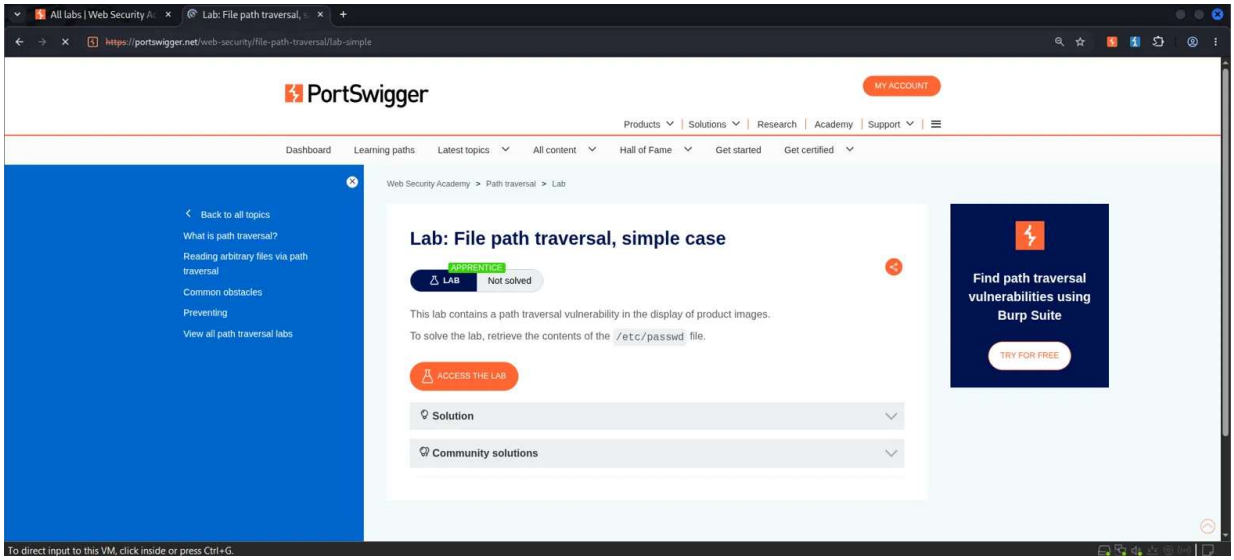


Fig 1 - Lab description.

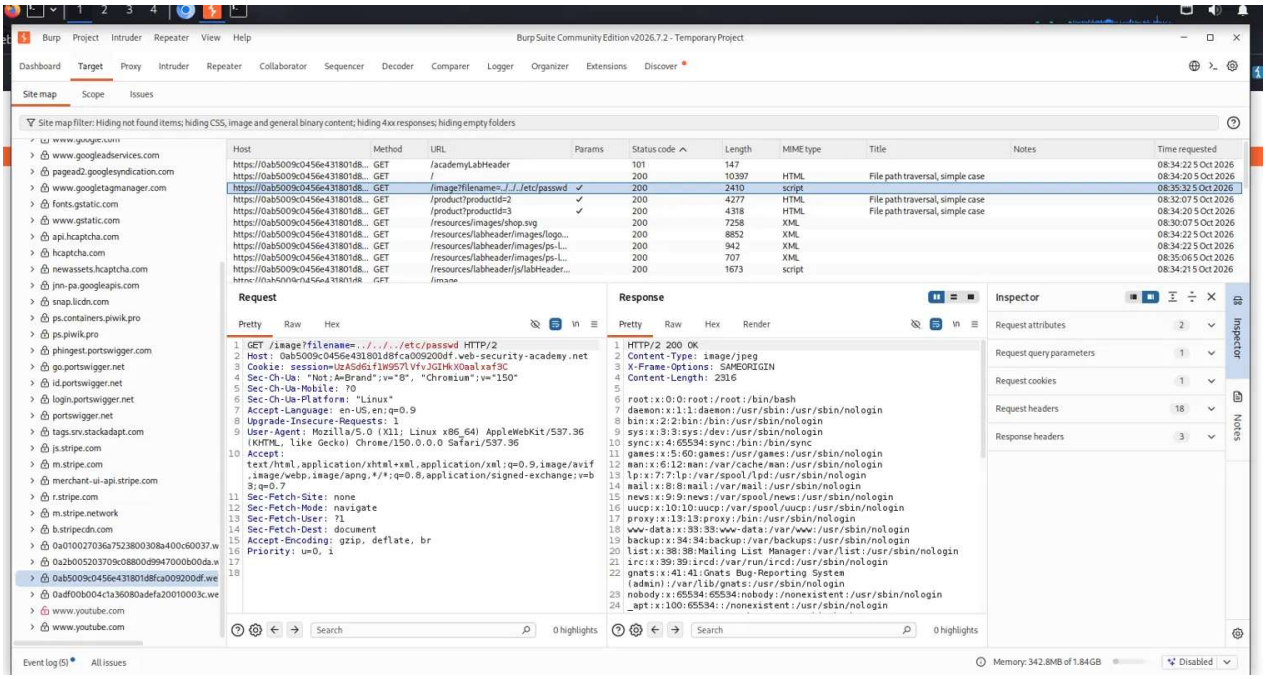


Fig 2 - Burp Repeater: ../../../etc/passwd request and file content in the response.

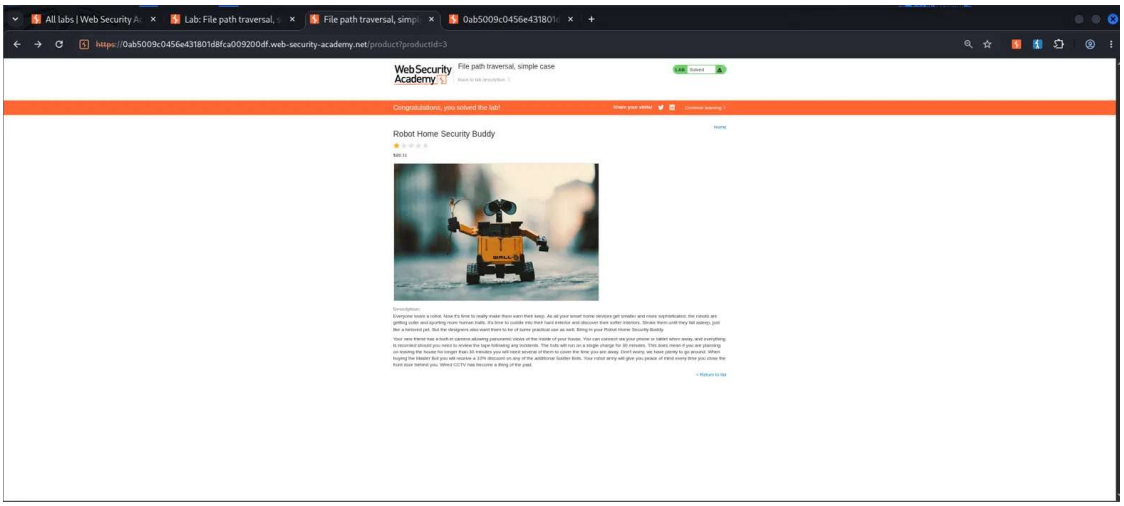


Fig 3 - Lab solved banner.

7. Impact

An attacker can read sensitive files such as configuration, source code, credentials or keys, which can lead to full compromise.

8. Remediation

- Do not use user input directly in file paths; use an allow-list or an ID mapped to a file.
- Canonicalise the path and check that it stays inside the base folder.
- Run the application with minimum file permissions.

9. Key Security Takeaways

- Any parameter with a file name is worth testing for ../ sequences.
- Burp Repeater makes it easy to try different depths quickly.
- The browser may hide the real content of an image response, so I read it in Repeater.

10. Skills Practiced

Area	**Practical understanding gained**
Path traversal	Reading files with ../ sequences
Burp Repeater	Modifying a request parameter
Analysis	Reading raw responses

11. What I Would Explore Next

I will try the harder traversal labs with filters, encoding and null bytes, and file upload vulnerabilities.

12. Conclusion

This lab was a clear example of why file names from users must never be trusted.

Completion status: Completed - lab solved.

13. References

PortSwigger Web Security Academy: https://portswigger.net/web-security/file-path-traversal/lab-simple